



Is your business GDPR compliant?

Use this 16-point self-assessment to identify gaps in your data protection practices. Each item represents a key GDPR obligation for small and medium-sized businesses operating in the EU. Takes about 10 minutes to complete.

1. Lawful Basis & Transparency

- ☐ **We have identified a lawful basis for every type of personal data we process**
e.g. consent, contract, legitimate interest, legal obligation (GDPR Art. 6)
- ☐ **We have a clear and accessible Privacy Policy published on our website**
Must explain what data you collect, why, and how long you keep it
- ☐ **We inform individuals at the point of data collection how their data will be used**
e.g. via a privacy notice on forms, email sign-ups, or contracts
- ☐ **We obtain and record explicit consent where required**
Consent must be freely given, specific, informed, and unambiguous

2. Data Inventory & Minimisation

- ☐ **We maintain a record of all personal data we process (a data register)**
GDPR Art. 30 requires organisations to document their processing activities
- ☐ **We only collect personal data strictly necessary for the stated purpose**
Avoid collecting "just in case" — only process what you actually need
- ☐ **We have a defined retention period for each type of personal data**
Data should not be kept longer than necessary for its purpose



3. Data Subject Rights



We have a process for handling subject access requests (SARs)

Individuals can request a copy of their data — you must respond within 30 days



We can delete or correct personal data upon request

Right to erasure ("right to be forgotten") and right to rectification



We have a process for handling objections to data processing

Individuals can object to processing based on legitimate interest

4. Security & Data Breaches



We have appropriate technical and organisational security measures in place

e.g. encryption, access controls, strong passwords, regular backups



We have a documented data breach response plan

Breaches must be reported to Datatilsynet within 72 hours under GDPR Art. 33



Access to personal data is restricted to authorised personnel only

Apply the principle of least privilege — only give access where needed



We use strong passwords and two-factor authentication for systems holding personal data

A basic but critical security control — and an explicit NIS2 requirement

NIS2

If your business is in scope of NIS2 (energy, transport, health, digital services, manufacturing, etc.), you must also report significant incidents to CFCS within 24 hours.

5. Third Parties & Data Processors



We have Data Processing Agreements (DPAs) with all third-party processors

e.g. your CRM, email provider, accounting software, cloud storage



We ensure third parties outside the EU provide adequate data protection

e.g. Standard Contractual Clauses (SCCs) for US-based services

NIS2

NIS2 also requires supply-chain risk management — review your processors' security posture, not just their contracts.

How did you score?

13–16

Strong foundation — book a call to close the remaining gaps

8–12

Notable gaps identified — these should be addressed soon

0–7

Significant risk exposure — contact us for a priority assessment

Not sure where to start?

Book a free 20-minute intro call with Soroflow. We will review your situation and tell you honestly what needs to be done — no jargon, no obligation.

calendly.com/hello-soroflow/20min



scan to visit soroflow.com

| advice.